Домашняя работа

Студент: Абдуллаев Билолиддин
Группа: 9/2-РПО-25/3
Дисциплина: Информационные технологии
Вид работы: Домашняя

Задание 1. Путь данных от ссылки до заявки

Для задания я взял интернет-магазин Google Merch Shop (shop.merch.google). Я открыл сайт, в инструментах разработчика перешёл на вкладку Network и поставил фильтр **collect**. Баннер про cookies я не трогал: ни «Принять», ни «Отклонить» не нажимал.

Дальше я прошёл обычный путь покупателя: главная страница, прокрутка вниз, категория Drinkware (кружки и бутылки), карточка товара Google Mega Mug и кнопка Add to Cart. В каждом запросе я смотрел параметр **en** (название события), **tid** (номер счётчика), **dt** (заголовок страницы), а также Payload. Если в адресе запроса параметра en не было, значит события пришли пачкой в теле запроса.

Какие события я увидел

Моё действие	Событие (en)	Что передаётся
Зашёл на главную	page_view, first_visit, session_start	адрес страницы (dl), заголовок «Home», язык ul=ru, разрешение экрана sr=2560x1440, cid — номер браузера
Прокрутил главную	view_promotion	какие рекламные баннеры магазина попали на экран
Открыл Drinkware и нажал на товар	select_item	из какого списка выбран товар (itemListName=Category)
Открылась карточка	page_view, view_item	item_id GMSSGDWL123099, item_name Google Mega Mug, цена 18, валюта USD
Нажал Add to Cart	add_to_cart	тот же товар, количество 1, value 18 USD

Что меня удивило

- На одной главной странице работают сразу **8 счётчиков GA4** (разные G-…) и ещё старый Universal Analytics (UA-54516992-1). То есть одно и то же событие page_view уходит много раз.
- Кроме Google Analytics запросы шли к рекламным сервисам: googleads.g.doubleclick.net, googleadservices.com, ad.doubleclick.net. Всего за загрузку главной браузер обратился к **20 разным доменам**.

- Одно событие называется **custom_event_with_a_name_over_40_charact**. Название обрезано ровно на 40 символах — это лимит GA4 на длину имени события. Похоже на тестовое событие.
- У одного и того же товара разная категория: в view_item — «Google», а в add_to_cart — «Lifestyle». В отчёте по категориям такая кружка посчитается в двух местах.
- Событие add_to_cart после клика сразу в Network не появилось: в dataLayer оно уже было, а сам запрос GA отправляет позже, вместе с другими событиями.

Путь пользователя

1. Переход на сайт по ссылке (page_view, session_start).
2. Просмотр главной страницы и баннеров (view_promotion).
3. Переход в категорию и выбор товара (select_item).
4. Просмотр карточки товара (view_item).
5. Добавление в корзину (add_to_cart).
6. Дальше должны идти оформление заказа (begin_checkout) и покупка (purchase) — это и есть «заявка» для магазина. До оплаты я, конечно, не доходил.

Где данные могут потеряться

- Пользователь добавил товар в корзину и сразу закрыл вкладку: событие ещё лежит в очереди и может не успеть уйти.
- У пользователя стоит блокировщик рекламы: запросы к analytics.google.com просто не отправятся.
- Если категория товара в разных событиях разная, данные не потеряются, но в отчёте получится путаница.

Задание 2. Разбор случая

Тема: скрипты записи сессий (Session replay)

Session replay — это скрипты, которые записывают всё, что человек делает на странице: движения мыши, клики, прокрутку и ввод с клавиатуры. Потом владелец сайта может посмотреть это как видео. Самые известные сервисы: FullStory, Hotjar, Smartlook, Яндекс Метрика (Вебвизор), а также открытый OpenReplay.

1. Какие данные собирались?

Скрипты записывали не только клики, но и содержимое страницы и то, что человек печатает в полях формы, причём ещё до нажатия кнопки «Отправить». Если сайт не настроил маскировку полей, в запись попадали имена, адреса, телефоны, медицинские данные и даже номера банковских карт. Пароли большинство сервисов скрывали, но остальное — далеко не всегда.

2. Кто получал данные и зачем?

Данные уходили на серверы компании, которая делает скрипт, а не только самому сайту. Сайт ставит такой скрипт, чтобы найти неудобные места: где люди долго думают, куда кликают мимо кнопки, на каком поле бросают форму. Проблема в том, что вместе с этим сторонняя компания получала личные данные посетителей, о чём сами посетители не знали.

3. Как это обнаружили?

В ноябре 2017 года исследователи из Принстонского университета (проект «No boundaries», Стивен Энглхардт, Гюнеш Акар и Арвинд Нараянан) проверили 50 тысяч самых популярных сайтов. Скрипты записи сессий нашлись на 482 из них. Затем исследователи вводили тестовые данные в формы и смотрели, что именно скрипт отправляет на свой сервер. Так выяснилось, что часть введённого текста уходит третьей стороне без маскировки.

4. Чем всё закончилось?

После публикации часть сайтов убрала эти скрипты или включила маскировку полей. Сервисы записи сессий сделали маскировку строже по умолчанию, а блокировщики рекламы добавили их домены в свои списки. Для меня главный вывод такой: чтобы данные утекли, взлом не нужен — достаточно одного чужого скрипта, который владелец сайта сам поставил на страницу.

5. Как это выглядело бы в Network?

В Network во время ввода текста в форму появлялись бы запросы к стороннему домену записи сессий, а в Payload были бы события вида «нажатие клавиши в поле» или куски страницы. Интересно, что на том же Google Merch Shop из задания 1 я увидел запрос к домену **rmopenreplay.avetti.ca** — это сервис OpenReplay, то есть запись сессий там тоже стоит. Её содержимое я не разбирал, но сам факт показывает, что такие скрипты встречаются и сейчас.